



ACTIVE DIRECTORY GAP ANALYSIS EXECUTIVE SUMMARY



Dathan Leggett
LAB-ENV Inc.

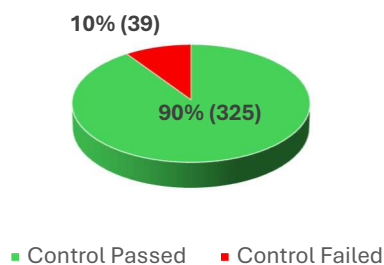
Purpose & Scope

As operations at Lab-Env Inc. initiate, it's important that from the start, we exercise due care to maintain a healthy security posture and continuously monitor our systems, people, and policy. Our aim is to transition from a risk-informed organization to an organization with a tested, repeatable security strategy. This gap analysis will score our on-premises Active Directory server's overall security posture, analyze the gaps against several controls in the *NIST 800-53 Revision 5*, score the risk of the findings, and provide remediation plans to mitigate said risk.

Though it is in an organization's best practice to implement known baseline configurations, cross-checking these configurations with a reputable framework is necessary to ensure that a system is properly hardened. Despite adhering to ~90% of the Microsoft Server 2025 baseline policies, domain risk remained at 45/100). Addressing this risk, as well as automating future outcomes, should place our organization within a healthy risk score of 25/100 or lower and move us towards continuous security.

Findings were conducted using *Microsoft Policy Analyzer* and *PingCastle*, as well as manually retrieved evidence. Granular findings and raw values are referenced in the Active Directory Assessment Workbook.

Windows Server 2025 Baseline Adherence Rate



Key Findings

- Legacy authentication protocol enabled
 - Lack of user lifecycle automation
 - Lack of domain audit visibility
- Group Policy Objects containing conflicting policy

Scoring The Risks

The risk of each control is qualitatively scored based on a standard 3x3 Risk Assessment Matrix, with risk scores ranging from Low to Critical. Each likelihood and impact level were scored as follows:

Likelihood

Low – Rare conditions needed to exploit the vulnerability

Medium – Requires a compromised account, elevated access, or complex conditions to exploit the vulnerability

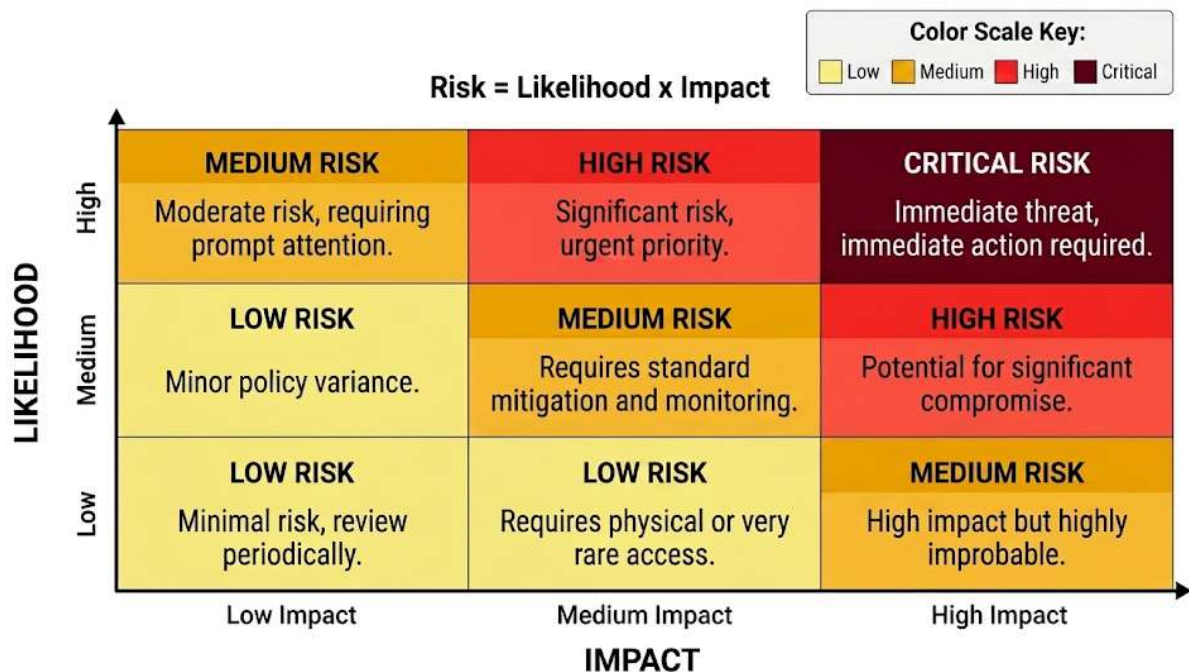
High – Known scripts/documentation are available and/or standard domain users are vulnerable

Impact

Low – Minimal privilege escalation, minor data/information disclosure

Medium – Partial network access, lateral movement, etc.

High – Domain takeover, sensitive data exposed, system downtime



Remediation Strategy

The details regarding security posture remediation are addressed in the Plan of Action and Milestones (POA&M). The POA&M is split into two sections:

- Immediate Fixes (1-Week Target): Focused on rapid attack surface reduction. These controls consist primarily of settings and Group Policy Object configuration changes, full deployment within five business days.
- Continuous Monitoring/Management (5-Week Target): Focused on establishing long-term controls and governance. These controls consist of gaps that require weeks of complex strategy and technical expertise to deploy and maintain, full deployment within 5-6 weeks.

By implementing both immediate and continuous security posture improvements, we will drastically reduce system risk, establish a truly secure baseline, and maintain a *NIST 800-53 Rev. 5* compliant identity environment.